

SYNTHETIX · SECURITY REVIEW

Synthetix

Fixed Staking Rewards.

A security review of Fixed Staking Rewards.

CLIENT	PROJECT	AUDITORS	AUDIT WINDOW	FINAL REPORT
Synthetix	Fixed Staking Rewards	Guardian	July 24 – July 28, 2025	August 4, 2025

§ 00

Contents.

16 pages — overview, confidence ranking, scope, 6 findings, disclaimer, and about Guardian.

§ 01	Overview	P. 03
§ 02	Confidence Ranking	P. 04
§ 03	Scope & Classifications	P. 05
	Files in Scope	P. 06
§ 04	Findings	P. 07
	Main Review · 6 findings	P. 08
§ 05	Disclaimer	P. 15
§ 06	About Guardian	P. 16

§ 01

Overview.

Guardian reviewed Fixed Staking Rewards across a single review round. The final report includes 1 High, 2 Medium, 3 Low findings.

AUDIT FIRM

Guardian

CLIENT

Synthetix

PROJECT

Fixed Staking Rewards

PREPARED BY

Guardian

AUDIT WINDOW

July 24 – July 28, 2025

FINAL REPORT

August 4, 2025

REPOSITORY

Synthetixio/fixed-staking-rewards

METHODOLOGY

Smart contract · Manual · Main Review

MAIN REVIEW COMMIT

768d818dcf0d

1.1 Confidence Ranking

4 / 5

High Confidence

Guardian assigns a Confidence Ranking of 4 out of 5, combining finding severity, remediation outcome, and the reviewer's assessment of latent risk. The full scale is on the next page.



1.2 Findings at a Glance

SEVERITY	TOTAL	PENDING	ACK	PARTIAL	RESOLVED
● Critical	0	0	0	0	0
● High	1	0	0	1	0
● Medium	2	0	1	1	0
● Low	3	0	2	1	0
● Informational	0	0	0	0	0
All severities	6	0	3	3	0

§ 02

Confidence Ranking.

Guardian assigns a project-level confidence score using the scale below. The ranking combines finding severity, remediation outcome, and the reviewer's assessment of latent risk.

CONFIDENCE RANKING	DEFINITION AND RECOMMENDATION	RISK PROFILE
5 Very High Confidence	Codebase is mature, clean, and secure. No High or Critical vulnerabilities were found. Follows modern best practices with high test coverage and thoughtful design. Recommendation: code is highly secure at time of audit.	0 High/Critical findings and few Low/Medium severity findings.
4 High Confidence ASSIGNED	Code is clean, well-structured, and adheres to best practices. Design patterns are sound and test coverage is strong. Recommendation: suitable for deployment after remediations; consider periodic review with changes.	0-1 High/Critical findings per engagement week and little to no Medium severity findings.
3 Moderate Confidence	Code is functional but shows gaps in defensive programming or test coverage. Recommendation: remediate the findings and re-review the changes before deployment.	Some High/Critical findings, with various Medium severity findings.
2 Low Confidence	Recurring issues suggest systemic gaps rather than isolated mistakes. Recommendation: remediate, then commission a follow-up review at a frozen commit.	Over 6 High and Critical findings across the engagement.
1 Very Low Confidence	The volume and severity of findings indicate the codebase is not ready for production. Recommendation: substantial rework, then a full re-review.	Over 12 High and Critical findings across the engagement.

§ 03

Scope & Classifications.

Guardian reviewed Fixed Staking Rewards in `Synthetixio/fixed-staking-rewards`. The scope includes 146 source lines across 3 files.

3.1 Severity Matrix

	IMP · HIGH	IMP · MED	IMP · LOW
LIK · HIGH	Critical	High	Medium
LIK · MED	High	Medium	Low
LIK · LOW	Medium	Low	Low

IMPACT · HIGH

Significant loss of assets, harm to a group of users, or core protocol functionality is disrupted.

IMPACT · MEDIUM

Small amount of funds can be lost, or ancillary functionality is affected. Users may experience reduced or delayed receipt.

IMPACT · LOW

Unexpected behavior in some functionality that is notable but does not meet the criteria for higher severity.

LIKELIHOOD · HIGH

Possible with reasonable assumptions that mimic on-chain conditions; cost is low compared to amount gained.

LIKELIHOOD · MEDIUM

Possible only in uncommon cases or requires a large amount of capital relative to disruption caused.

LIKELIHOOD · LOW

Unlikely to ever occur in production.

Files in Scope.

FILE	NSLOC	TOTAL
src/FixedStakingRewards.sol	139	189
src/interfaces/IChainlinkAggregator.sol	3	5
src/interfaces/ISTakingRewards.sol	4	10

§ 04

Findings.

Grouped by round. Visible IDs reset by severity within each round, so a finding is named the same way in the report as it was in the channel it was written in.

ID	TITLE	CATEGORY	SEVERITY	STATUS	PAGE
MAIN REVIEW					
H-01	Order Of Reward Rate Update And Accumulation	Rewards	HIGH	PARTIALLY RESOLVED	p. 8
M-01	Missing Pause Functionality	Logical Error	MEDIUM	PARTIALLY RESOLVED	p. 10
M-02	Incorrect Reward Availability Check On Stake	Logical Error	MEDIUM	ACKNOWLEDGED	p. 11
L-01	Staking Is Permissionless	Best Practices	LOW	PARTIALLY RESOLVED	p. 12
L-02	Deviation Value Can Influence Rewards	Rewards	LOW	ACKNOWLEDGED	p. 13
L-03	Stale Prices Are Accepted	Oracle	LOW	ACKNOWLEDGED	p. 14

HIGH **H-01**

PARTIALLY RESOLVED

Order Of Reward Rate Update And Accumulation

CATEGORY	Rewards
LOCATION	https://github.com/GuardianOrg/fixed-staking-rewards-syntheticfixedstakingrewards-team1/blob/768d818dcf0db714eb46f72a55248c08fb616c79/src/FixedStakingRewards.sol#L59
REVIEW	Main Review

— DESCRIPTION

The current implementation, where contract first accumulates rewards and then rebalances based on SNX price, works well when the token price is falling — as users receive fewer SNX tokens for the same USD value from time A to B.

However, this behavior backfires when SNX price appreciates. For example:

- The `rewardRate` is updated when SNX is priced at \$1.
- One week later, SNX appreciates to \$2.
- A user stakes a minimal amount (dust) to trigger an accumulation update.
- The accumulation still assumes SNX is worth \$1, resulting in the user receiving double the intended USD value in SNX rewards.

This discrepancy breaks the protocol's intended 50% APY invariant. Worse, a malicious actor could exploit this to consistently earn more than 50% APY.

In edge cases, if the protocol funds rewards precisely for 50% APY, this mismatch could also cause denial of service (DoS) for new stakers or claimers due to insufficient SNX.

— RECOMMENDATION

Bias Reward Accounting in Favor of the Protocol

To mitigate this:

- Track the last recorded SNX price.
- If the current price is higher, perform a rebalance first, then accumulate.
- If the current price is lower, accumulate first, then rebalance.

This ensures the reward distribution errs on the side of the protocol, preventing over-rewarding in volatile or upward-trending price conditions.

PROOF OF CONCEPT <https://github.com/GuardianOrg/fixed-staking-rewards-syntheticfixedstakingrewards-team1/pull/1>

H-01 Order Of Reward Rate Update And Accumulation

CONTINUED

— RESOLUTION

Status: Partially resolved.

MEDIUM **M-01**

PARTIALLY RESOLVED

Missing Pause Functionality

CATEGORY Logical Error
LOCATION `FixedStakingRewards`
REVIEW Main Review

DESCRIPTION

As per the documentation in the README, SNX expects `FixedStakingRewards` to be pausable:

Readme:

Pausable : Can be paused in emergency situations

However, the contract inherits from a standard `ERC20`, not `ERC20Pausable`, making pause functionality unavailable.

RECOMMENDATION

Consider inheriting from `ERC20Pausable` (or the appropriate pausable base) instead of the standard `ERC20`, to align with the intended design and allow emergency response via pause.

RESOLUTION

Status: Partially resolved.

<https://github.com/Synthetixio/fixed-staking-rewards/pull/4>

MEDIUM **M-02**

ACKNOWLEDGED

Incorrect Reward Availability Check On Stake

CATEGORY	Logical Error
LOCATION	https://github.com/Synthetixio/fixed-staking-rewards/blob/768d818dcf0db714eb46f72a55248c08fb616c79/src/FixedStakingRewards.sol#L77-L78
REVIEW	Main Review

DESCRIPTION

The contract is expected to ensure that at least 2 weeks' worth of rewards are available before allowing a deposit:

Currently, the check compares `requiredRewards` against the full balance of the reward token:

```
if (requiredRewards > rewardsToken.balanceOf(address(this))) {
```

This includes unclaimed rewards already allocated to stakers, which can lead to false positives. For example, if some users claim rewards immediately after the stake is accepted, the contract may no longer have enough tokens for the promised 2-week coverage.

RECOMMENDATION

Exclude already accrued (but unclaimed) rewards from the balance check.

Could be approximated by subtracting the yield accrued for the pre-stake total supply. (This is an approximation since the rate itself is not constant (in terms of SNX Tokens), and in the past there could have been a different rate than the current one.)

RESOLUTION

Status: Acknowledged.

LOW **L-01**

PARTIALLY RESOLVED

Staking Is Permissionless

CATEGORY Best Practices
LOCATION Global
REVIEW Main Review

— DESCRIPTION

The staking contract is permissionless, anyone is able to stake. As this contract is not made public and the amount of users is expected to be very limited, it might be beneficial to think about adding a whitelist here.

This could be handled easily when the amount of users is very limited and prevents malicious actors from interacting with the system, which decreases the risk of an exploit drastically.

— RECOMMENDATION

Consider adding a whitelist.

— RESOLUTION

Status: Partially resolved.

<https://github.com/Synthetixio/fixed-staking-rewards/pull/4>

LOW **L-02**

ACKNOWLEDGED

Deviation Value Can Influence Rewards

CATEGORY	Rewards
LOCATION	Global
REVIEW	Main Review

— DESCRIPTION

The SNX chainlink price feed on Ethereum has a deviation value of 1% this could lead to the user receiving 1% too much or too less rewards.

— RECOMMENDATION

Be aware and consider rounding up to 1% against the user.

— RESOLUTION

Status: Acknowledged.

LOW **L-03**

ACKNOWLEDGED

Stale Prices Are Accepted

CATEGORY	Oracle
LOCATION	https://github.com/GuardianOrg/fixed-staking-rewards-syntheticfixedstakingrewards-team1/blob/768d818dcf0db714eb46f72a55248c08fb616c79/src/FixedStakingRewards.sol#L157-L159
REVIEW	Main Review

— DESCRIPTION

The SNX chainlink price feed on Ethereum has a heartbeat of 1 day but prices up to 1 day and 1 hour old are accepted. Therefore stale prices are accepted.

— RECOMMENDATION

Consider reducing buffer from 1 hour to few minutes (10 for example)

— RESOLUTION

Status: Acknowledged.

§ 05

Disclaimer.

This report is not, nor should be considered, an "endorsement" or "disapproval" of any particular project or team. This report is not, nor should be considered, an indication of the economics or value of any "product" or "asset" created by any team or project that contracts Guardian to perform a security assessment. This report does not provide any warranty or guarantee regarding the absolute bug-free nature of the technology analyzed, nor do they provide any indication of the technologies proprietors, business, business model or legal compliance.

This report should not be used in any way to make decisions around investment or involvement with any particular project. This report in no way provides investment advice, nor should be leveraged as investment advice of any sort. This report represents an extensive assessing process intending to help our customers increase the quality of their code while reducing the high level of risk presented by cryptographic tokens and blockchain technology.

Blockchain technology and cryptographic assets present a high level of ongoing risk. Guardian's position is that each company and individual are responsible for their own due diligence and continuous security. Guardian's goal is to help reduce the attack vectors and the high level of variance associated with utilizing new and consistently changing technologies, and in no way claims any guarantee of security or functionality of the technology we agree to analyze.

The assessment services provided by Guardian is subject to dependencies and under continuing development. You agree that your access and/or use, including but not limited to any services, reports, and materials, will be at your sole risk on an as-is, where-is, and as-available basis.

Cryptographic tokens are emergent technologies and carry with them high levels of technical risk and uncertainty. The assessment reports could include false positives, false negatives, and other unpredictable results. The services may access, and depend upon, multiple layers of third-parties.

Notice that smart contracts deployed on the blockchain are not resistant from internal/external exploit. Notice that active smart contract owner privileges constitute an elevated impact to any smart contract's safety and security. Therefore, Guardian does not guarantee the explicit security of the audited smart contract, regardless of the verdict.

§ 06

About Guardian.

Guardian is a smart contract security firm. Every engagement is worked by two independent teams competing on the same scope, each with its own tooling and methods, so no single reviewer's blind spot survives.

\$45B+DIGITAL ASSETS UNDER
REVIEW**200+**

ENGAGEMENTS COMPLETED

500+CRITICAL & HIGH FINDINGS
REPORTED

Reach us at audits@guardianaudits.com.